

Cyber Tabletop Exercise

Deepfake Vishing Against the Help Desk for Privileged MFA Reset

Enhanced facilitation package generated from the supplied TTX and evaluation feedback

Scenario source	STIX-derived TTX provided by user
Exercise type	Facilitated tabletop exercise
Sector	Financial services / banking
Duration	75-105 minutes
Audience	Executive, operational, and technical stakeholders
Classification	Internal Use Only

Version: Enhanced TTX package | Prepared for exercise design and facilitation

Document Map

- Purpose, objectives, participants, scope, assumptions, and rules of engagement.
- Reference identity architecture and privileged MFA reset workflow to make the scenario technically concrete.
- Phased injects with facilitator notes, role ownership, expected actions, telemetry, and decision points.
- Technical and business impacts, communication and regulatory considerations, evaluation scorecard, debrief plan, and follow-on actions.
- Corrected MITRE ATT&CK mapping with unsupported or conditional techniques clearly separated.

Revision focus: The source exercise was structurally strong, but the evaluation flagged limited technical specificity and a weak ATT&CK mapping. This version adds a concrete identity stack, a realistic reset path, token/session behavior, downstream telemetry, formal role ownership, measurable evaluation criteria, and a defensible ATT&CK mapping.

Inputs used	Source TTX PDF: 'Deepfake Vishing Against the Help Desk for Privileged Reset'. Evaluation JSON: realism, coherence, relevance, cyber accuracy, training value, and structural completeness feedback.
Highest-risk improvement area	Cyber accuracy / MITRE ATT&CK mapping scored 2.1 in the evaluation and has been substantially revised.
Design assumption	The organization uses a hybrid/cloud identity provider, privileged access management, an ITSM help desk platform, call recording, and centralized security logging.
Facilitation posture	Participants should respond using current policies and authorities. Where controls are unknown, participants should state assumptions and identify gaps.

1. Purpose

This tabletop exercise tests the organization's ability to detect, validate, escalate, contain, and recover from a socially engineered privileged-identity event. The scenario centers on an adversary using deepfake-assisted voice impersonation and urgent executive pressure to manipulate the internal help desk into resetting MFA for a privileged user account.

The exercise is designed to expose decision-making gaps at the intersection of service-desk operations, identity governance, privileged access, security monitoring, business continuity, and crisis management. It is not a technical malware drill; the central control boundary is the identity recovery process.

Facilitation outcome

- Validate whether privileged-account recovery controls withstand pressure, urgency, and claimed executive authority.
- Determine whether escalation thresholds are clear when a reset request appears legitimate but cannot be independently verified.
- Test whether SOC, IAM, PAM, service desk, business leadership, legal, compliance, privacy, and communications can coordinate quickly.
- Identify practical improvements to prevent repeat compromise through voice-channel identity recovery abuse.

2. Exercise Objectives

Core objectives

- Evaluate help-desk identity proofing controls for privileged and executive-related access requests.
- Test no-exception handling for high-risk MFA resets when the caller cannot complete standard verification.
- Assess the organization's ability to detect and contain an account takeover after MFA factor manipulation.
- Confirm the sequence for disabling or restricting privileged access, revoking sessions, rotating secrets, and preserving evidence.
- Validate escalation paths from service desk to IAM/PAM, SOC, incident command, legal, compliance, privacy, HR, communications, and business leadership.
- Review business impact decisions involving delayed approvals, administrative work, payments, operations, and sensitive data access.
- Define remediation actions for identity recovery workflows, voice-channel verification, detection logic, and governance.

Audience-specific objectives

Audience	Expected learning outcome
Executive / Crisis Leadership	Clarify risk appetite, authority to suspend high-impact privileged access, internal/external communications, regulatory posture, and executive messaging.
Operational / Service Desk / IAM	Validate the privileged reset workflow, step-up proofing, supervisor escalation, ITSM documentation, callback procedures, and separation of duties.
Technical / SOC / IR / PAM	Identify telemetry, triage sequence, containment order, token revocation, session termination, credential rotation, downstream scoping, and evidence preservation.
Legal / Compliance / Privacy / Risk	Assess notification triggers, legal hold, record retention, privacy exposure, regulatory reporting criteria, and third-party or fraud implications.

3. Suggested Participants and Role Responsibilities

The exercise should be run with enough representation to make decisions, not just discuss them. Participants should name their role before each intervention and should distinguish between current documented authority and desired future authority.

Role	Primary responsibility in exercise
Facilitator	Controls pace, introduces injects, probes assumptions, keeps discussion on decisions and ownership.
Scribe / Observer	Captures decisions, gaps, assumptions, action items, timing, and unresolved ownership questions.
Crisis Management Lead / Incident Commander	Owens incident coordination once escalation criteria are met; aligns security response, business continuity, and governance.
CIO / CISO Delegate	Provides technology risk direction, approves high-risk containment where authority is unclear, and briefs executive stakeholders.
Service Desk Manager	Owens call handling, analyst escalation, ticket documentation, call recording retrieval, and immediate process containment.
IAM Lead	Owens MFA reset policy, account recovery controls, identity-provider audit logs, token/session revocation, and conditional access decisions.
PAM Administrator	Owens privileged vault access, privileged session review, admin role membership, break-glass procedures, and secret rotation.
SOC Lead	Owens alert triage, detection correlation, account compromise classification, and evidence collection from security telemetry.
Incident Response Lead	Owens response plan execution, containment sequence, forensics coordination, and incident timeline.
Business Operations Lead	Owens operational impact assessment, business workarounds, delayed approvals, and prioritization of critical activity.
Legal / Compliance / Privacy	Owens notification analysis, legal hold, evidence handling, privileged communications, and regulatory consultation.
Communications Lead	Owens internal messaging, executive statements, rumor control, and external communications preparation if needed.
HR / Executive Support	Supports trusted callback, executive availability verification, personnel process issues, and sensitive communications.

Role ownership by inject

Stage	Responsible	Accountable	Consulted	Informed
Inject 1 - Voice call	Service Desk Manager	IAM Lead	SOC Lead, HR / Executive Support	CISO Delegate, Legal
Inject 2 - Reset completed	IAM Lead	Service Desk Manager	SOC Lead, PAM Admin, Incident Response	Crisis Lead, Business Operations
Inject 3 - Privileged session anomaly	SOC Lead / Incident Response	CISO Delegate or Incident Commander	IAM, PAM, Business Operations	Legal, Compliance, Communications
Inject 4 - Downstream exposure	Incident Commander	Crisis Management Lead	SOC, IAM, PAM, Legal, Privacy, Business	Executive Leadership
Inject 5 - Recovery and governance	Crisis Management Lead	CIO / CISO Delegate	Legal, Compliance, Service Desk, IAM, PAM	All participants

4. Scope, Assumptions, and Reference Architecture

In scope

- Help-desk handling of privileged-user MFA reset and account recovery requests.
- Voice-channel identity validation, trusted callback, step-up proofing, and exception management.
- Identity provider audit events, MFA factor changes, temporary access methods, and session/token lifecycle.

- Privileged access monitoring, PAM session logs, admin role assignments, downstream system exposure, and rapid containment.
- Internal escalation, crisis coordination, business continuity, communications, regulatory considerations, and post-incident governance.

Out of scope

- Detailed malware reverse engineering or endpoint memory forensics.
- Public attribution of the threat actor.
- Litigation strategy beyond notification, evidence preservation, and legal-hold considerations.
- Full customer notification scripting unless participants determine a reporting or notification trigger has been met.

Core assumptions

- The targeted identity is a privileged administrative persona or privileged business-approval account associated with a senior technology or operations leader.
- The organization uses a cloud or hybrid identity provider for SSO and MFA, with conditional access and session controls.
- The service desk uses an ITSM platform with ticket history, caller ID metadata, analyst notes, and recorded calls.
- Privileged administrative activity is mediated through a PAM platform or privileged session workflow.
- Security logs from the identity provider, PAM, VPN / ZTNA, endpoint, email, collaboration tools, and critical business applications are centralized in the SIEM.
- Participants should respond using their actual policies, runbooks, escalation paths, and approval authorities.

Reference identity stack for exercise realism

Component	Assumed role in scenario
Identity Provider (IdP)	Hybrid/cloud SSO platform supporting MFA, conditional access, sign-in risk, audit logs, session tokens, refresh tokens, and temporary access methods.
MFA / Recovery Controls	Registered authenticator app, hardware security key for privileged users, temporary access pass or equivalent, recovery codes, and trusted callback verification.
Privileged Access Management	Vaulted privileged credentials, just-in-time elevation, privileged session recording, role assignment, and break-glass access procedure.
ITSM / Help Desk Tooling	ServiceNow-like ticketing, caller identification, call recording, supervisor approval workflow, identity proofing checklist, and request audit trail.
Trusted Source Systems	HRIS, executive support directory, CMDB, corporate travel system, manager-of-record data, and pre-registered callback numbers.
Monitoring	SIEM / UEBA, IdP sign-in logs, audit logs, PAM logs, VPN / ZTNA logs, EDR, email and collaboration audit logs, DLP / CASB, and application access logs.
Downstream Systems at Risk	Cloud admin portal, directory services, PAM vault, ITSM admin interface, payment or treasury approval workflow, data warehouse, M365 / SharePoint / Teams, and sensitive business repositories.

Privileged MFA reset workflow expected under policy

1. Confirm the request is for a privileged account and mark it as high-risk in the ITSM ticket.
2. Deny voice-only identity proofing and voice recognition as a sufficient factor.
3. Perform trusted out-of-band verification using a pre-registered callback number or approved executive-support contact not supplied by the caller.
4. Require dual approval from the service desk supervisor and IAM / PAM owner for any privileged reset.

5. Issue a time-bound recovery method only through the approved identity platform, with the shortest possible validity and documented justification.
6. Force re-enrollment through a trusted device or phishing-resistant method where available.
7. Invalidate prior sessions and monitor for anomalous login, new device registration, conditional-access bypass, and high-risk activity.
8. Document all evidence, approvals, timestamps, caller details, analyst observations, and deviations.

Failure path exercised in this scenario

The adversary already has the privileged user's username and password from a prior credential exposure but cannot satisfy MFA. During the call, the analyst accepts the caller's voice resemblance, internal details, and urgency. A supervisor informally approves an exception without a trusted callback. A temporary access method is issued, allowing the adversary to enroll an attacker-controlled MFA device. The IdP then issues SSO and refresh tokens, enabling access to PAM and downstream administrative resources.

5. Rules of Engagement

- Real-world incidents take priority over the exercise.
- This is a no-fault learning exercise; focus on decisions, responsibilities, evidence, timing, and gaps.
- Treat the scenario as credible and unfolding in real time.
- Do not fight the scenario. Challenge assumptions only to clarify response decisions.
- Participants should use existing policies and runbooks. When a policy is unknown or absent, state the assumption and record the gap.
- The facilitator may introduce additional facts if discussion stalls or a key decision point is missed.
- No live containment, account changes, customer communications, or regulatory notifications should be performed as part of the exercise.

6. Scenario Overview

A criminal threat actor targets the organization's privileged identity recovery process. The actor gathers personal and organizational context about a senior technology leader, including public voice samples, recent travel details, internal team names, and service-desk terminology. The actor then calls the internal help desk using a convincing deepfake voice, claiming to be locked out while traveling and unable to complete an urgent business approval.

The request involves the leader's privileged administrative persona account. The caller cannot complete normal MFA verification and pressures the analyst to bypass the reset process. Despite the elevated risk, the reset is completed through an informal exception. Within minutes, the identity provider records a new MFA device enrollment, followed by a successful login from an unusual network and anomalous access to privileged resources.

The organization must determine whether to declare a privileged-account compromise, how to contain the account without unnecessarily disrupting business operations, what downstream systems may have been exposed, and what governance actions are required.

7. Threat Context and Attack Lifecycle

Threat actor profile

- Motivation: financially motivated access to privileged banking, administration, or payment-related workflows.
- Tradecraft: deepfake-assisted vishing, executive impersonation, urgency and authority pressure, pretext construction, and abuse of help-desk recovery controls.
- Prerequisites: target identity details, valid username and password or equivalent credential material, and sufficient knowledge of the organization's reset process.

- Primary objective: bypass MFA by manipulating the recovery process, obtain valid privileged sessions, and determine which systems can be accessed.

Attack lifecycle in scope

Stage	Adversary behavior	Expected evidence
0. Preparation	Actor collects executive voice samples, internal names, travel context, job role details, and possible credential material.	Reconnaissance and targeting context; not visible to service desk until call content is reviewed.
1. Social engineering	Actor calls help desk and impersonates the leader, claiming urgent lockout and pressuring for MFA reset.	Call recording, ticket notes, caller ID metadata, analyst observations, callback number supplied by caller.
2. Recovery abuse	Analyst issues temporary access or resets MFA without approved out-of-band verification.	ITSM approval path, IdP audit event for MFA method change, temporary access pass issuance, admin activity in identity platform.
3. Valid account use	Actor authenticates with valid credentials plus newly enrolled factor, receiving SSO and refresh tokens.	IdP sign-in logs, new device registration, suspicious IP / ASN, unusual geolocation, impossible travel, conditional-access decision.
4. Discovery and scoping	Actor accesses PAM, admin consoles, directory listings, groups, and connected systems to determine reach.	PAM logs, cloud admin audit logs, directory read operations, group enumeration, ServiceNow or CMDB searches.
5. Containment and recovery	Organization disables or restricts account, revokes tokens, rotates secrets, validates downstream activity, and repairs the recovery process.	IR timeline, containment actions, credential rotations, evidence preservation, post-incident report.

Known facts vs unknowns

Known at exercise start	Still unknown and must be determined
A privileged identity recovery request is made by voice. The caller claims urgency and inability to complete MFA. Internal context is used convincingly.	Whether the caller is genuine, how they obtained context, whether credentials are already compromised, whether the real executive is reachable, and whether existing policy allows any exception.
An anomalous login occurs after the reset. New MFA enrollment and unusual sign-in telemetry are present.	Which sessions and tokens are active, which systems were accessed, whether privileges were changed, whether data was viewed or exported, and whether other accounts were targeted.

8. Exercise Structure and Timing

Recommended duration: 75-105 minutes. For a 60-minute version, compress discussion to the decision points and expected actions only.

Timing	Segment	Purpose
0:00-0:08	Opening	Rules, objectives, roles, and assumptions.
0:08-0:23	Inject 1	Executive voice call pressures service desk for privileged reset.
0:23-0:38	Inject 2	Reset exception completed; new MFA method and risky sign-in appear.
0:38-0:55	Inject 3	Privileged session anomaly and immediate containment decision.
0:55-1:15	Inject 4	Downstream exposure, business impact, communications, and governance escalation.
1:15-1:30	Inject 5	Recovery, post-incident actions, and control improvements.
1:30-1:45	Debrief	Lessons learned, evaluation scoring, and action plan.

Inject 1 - Executive Voice Call to Help Desk

Simulated time	08:45
Incident stage	Initial contact / social engineering attempt
Primary decision	Whether to honor or deny the privileged MFA reset request without standard verification.
Recommended time	12-15 minutes

Scenario narrative

A caller contacts the internal service desk and sounds convincingly like a senior technology executive. The caller claims to be traveling, locked out, and required to approve an urgent business action within the hour. The caller references internal names, a recent travel itinerary, and the names of two executive assistants. The caller cannot complete standard MFA verification and asks the analyst to reset MFA for the privileged administrative persona account. The caller insists that the analyst will be responsible for business disruption if the reset is not completed immediately.

Technical artifacts available to participants

- ITSM ticket with analyst notes and caller-provided callback number.
- Call recording reference and caller ID metadata.
- Privileged-account classification from IAM inventory.
- Executive support directory showing pre-registered callback contacts.

Information provided to participants

- The request concerns a privileged administrative persona account, not a normal user account.
- The caller supplies a mobile number and hotel callback number, neither of which is pre-registered in the HR or executive support directory.
- The caller correctly names the executive's assistant, manager-of-record, and a recent internal project.
- The analyst recognizes the voice as highly similar to the real executive.
- No independent out-of-band confirmation has been completed.
- The ticket is categorized as account recovery, not yet as suspected social engineering.

Discussion questions

- What must the help desk do before taking any reset action?
- Is voice recognition, caller ID, or knowledge of internal facts sufficient proof for a privileged reset?
- What is the no-exception process for privileged identity recovery?
- Who is authorized to approve a privileged MFA reset when the caller cannot complete normal verification?
- What trusted out-of-band channels are available, and who owns them?
- At what point should this be classified as suspected social engineering?
- How should the call, ticket, and analyst observations be documented and preserved?

Expected participant actions

- Deny any bypass of privileged reset controls based solely on urgency or executive pressure.
- Classify the request as high-risk and follow the privileged recovery workflow.
- Attempt trusted callback using a pre-registered number or executive support channel not provided by the caller.
- Escalate to the service desk supervisor and IAM / PAM owner before any action.
- Notify the SOC or incident response lead if the caller refuses standard verification or continues pressure tactics.

- Preserve call recording, caller ID metadata, ticket notes, and timestamps.
- Document the decision, including any attempted exception request and who approved or denied it.

Role ownership at this stage

Role / function	Expected ownership
Service Desk Manager	Ensure the analyst follows the high-risk reset decision tree and documents the call.
IAM Lead	Confirm privileged account classification and advise on approved recovery path.
SOC Lead	Determine whether the event should become a security alert or early incident signal.
HR / Executive Support	Validate trusted contact details and executive availability.
Legal / Compliance	Advise if call recording preservation, employee privacy, or evidence retention requirements are triggered.

Facilitator notes

Probe whether participants rely on voice familiarity, seniority, or internal knowledge as proof. Ask what happens if the real executive is on a flight and unreachable. Strong responses should protect the control even under business pressure and should not substitute manager chat approval for identity proofing.

Observable evaluation cues

- Participants identify voice-channel social engineering risk promptly.
- Participants distinguish privileged reset requirements from standard user support.
- Participants name the exact trusted callback source and accountable owner.
- Participants document evidence and avoid informal exceptions.

Inject 2 - Exception Path and MFA Reset Completed

Simulated time	09:20
Incident stage	Recovery-control failure / account takeover path
Primary decision	Whether to declare suspected compromise after a reset control failure and new MFA enrollment.
Recommended time	15 minutes

Scenario narrative

The caller becomes more forceful and claims the organization's CEO is waiting for a decision. The analyst escalates to a supervisor, who informally approves an exception in the ticket to avoid business disruption. The service desk issues a temporary access method valid for eight hours and initiates MFA re-enrollment for the privileged administrative persona. Within minutes, the identity provider logs a new authenticator enrollment from a device not previously associated with the executive.

Technical artifacts available to participants

- IdP audit event: MFA factor removed and new authenticator enrolled.
- Temporary access method issuance record with validity window and issuing admin.
- Sign-in log showing new device fingerprint, unusual ASN, and conditional-access decision.
- ITSM approval comments and supervisor identity.

Information provided to participants

- The real executive has not been reached through a trusted channel.
- A temporary access method was issued and used within four minutes.
- A new MFA device was enrolled from an unmanaged device fingerprint.
- The sign-in originates from a commercial VPN / hosting ASN outside the executive's normal travel pattern.
- Conditional access allowed the sign-in because the recovery method was marked as service-desk approved.
- The analyst and supervisor both documented urgency but did not document a successful trusted callback.

Discussion questions

- What threshold of evidence is enough to classify this as suspected privileged-account compromise?
- What containment action should occur first: disable account, revoke sessions, suspend the MFA device, or contact the executive?
- Who has authority to reverse a privileged reset or disable an executive-associated privileged account?
- How do you preserve evidence while stopping active access?
- Which logs and administrative actions must be retrieved immediately?
- Should similar privileged reset tickets be reviewed for pattern activity?
- What communication should go to the service desk while the event is active?

Expected participant actions

- Declare suspected compromise of a privileged identity or high-severity security event.
- Disable or restrict the affected privileged account according to emergency access policy.
- Revoke active sessions, refresh tokens, and temporary access methods.
- Remove the newly enrolled MFA device and preserve its enrollment details.
- Review IdP audit logs, sign-in logs, ITSM ticket history, call recording, and supervisor approval trail.

- Launch incident response coordination and assign an incident commander if thresholds are met.
- Issue a temporary service-desk hold on privileged reset exceptions until reviewed by IAM and SOC.

Role ownership at this stage

Role / function	Expected ownership
IAM Lead	Owns account restriction, MFA factor removal, token revocation, and recovery-method audit.
SOC / IR Lead	Owns compromise classification, security incident severity, and evidence correlation.
Service Desk Manager	Owns process failure containment and preservation of call and ticket records.
PAM Administrator	Checks whether the identity reached PAM workflows or privileged vault entries.
CISO Delegate	Confirms authority to disable a business-sensitive privileged identity despite potential disruption.

Facilitator notes

Force the group to commit to an order of containment. Many teams discuss action without naming the person who can actually disable an account. Ask whether they would wait for confirmation from the real executive if the account is active and privileged.

Observable evaluation cues

- Participants identify MFA re-enrollment as a high-risk account manipulation event.
- Participants take token/session revocation seriously rather than only resetting a password.
- Participants pause similar reset exceptions and assess whether the service-desk workflow has a systemic gap.
- Participants preserve the temporary access pass details and new MFA device evidence.

Inject 3 - Privileged Session Anomaly and Immediate Containment

Simulated time	10:15
Incident stage	Active privileged access / containment decision
Primary decision	How to stop active access while preserving evidence and limiting operational disruption.
Recommended time	15-18 minutes

Scenario narrative

Monitoring detects successful SSO from the privileged administrative persona into the PAM portal, the cloud admin console, and the ITSM administration interface. The session performs read-heavy activity inconsistent with the real executive's normal behavior: viewing admin role memberships, opening PAM vault metadata, searching privileged groups, and reviewing recent service-desk reset tickets. No confirmed data exfiltration is known, but the account has active sessions in multiple systems.

Technical artifacts available to participants

- PAM session access report.
- Cloud admin audit log showing directory and group enumeration.
- IdP token and sign-in telemetry.
- ITSM admin search history.
- Executive support confirmation that the request was not legitimate.

Information provided to participants

- The account has active SSO sessions and at least one refresh token.
- The PAM portal shows navigation to vault folders but no confirmed password checkout yet.
- The cloud admin console logs multiple directory and group membership views.
- The ITSM platform shows searches for reset procedures and privileged support groups.
- Business stakeholders warn that disabling the account could delay urgent approvals.
- The real executive's assistant reports that the executive is on a flight and did not request a reset.

Discussion questions

- What exact containment sequence should be executed?
- Which sessions and tokens must be revoked across IdP, PAM, cloud, VPN / ZTNA, and downstream applications?
- Do you disable the account entirely or apply a conditional access block while preserving business continuity?
- Which secrets, shared credentials, break-glass accounts, API tokens, or delegated permissions are potentially exposed?
- Who notifies business stakeholders that privileged approvals may be delayed?
- How do you avoid destroying evidence while stopping the active session?
- What should be hunted immediately across other accounts and reset tickets?

Expected participant actions

- Confirm incident commander and establish a single response channel.
- Disable or place emergency restrictions on the privileged administrative persona account.
- Revoke all active sessions, refresh tokens, temporary access methods, and newly registered MFA factors.

- Suspend related privileged approvals or require alternate authorized approvers.
- Review PAM session recordings, vault access logs, role assignment logs, and admin console audit logs.
- Rotate any secrets, API keys, or credentials potentially displayed or checked out during the session.
- Search for similar reset patterns, new MFA enrollment anomalies, and service-desk tickets involving privileged users.
- Brief leadership on containment status, operational impact, confidence level, and next decision points.

Role ownership at this stage

Role / function	Expected ownership
Incident Commander	Coordinates containment, assigns owners, manages timeline, and records decisions.
SOC / IR Lead	Correlates alerts, validates session activity, and maintains the security incident timeline.
IAM Lead	Executes token and session revocation, account restriction, MFA cleanup, and conditional-access review.
PAM Administrator	Reviews vault access, session recordings, and privileged role activity; rotates exposed secrets if needed.
Business Operations Lead	Manages workaround for approvals and prioritizes critical business activity.
Communications Lead	Prepares internal status language to prevent rumor-driven escalation.

Facilitator notes

Ask the group to name every place a session might persist. Password reset alone is not adequate if refresh tokens, SSO sessions, PAM sessions, VPN sessions, and application sessions remain active. Strong teams should discuss both containment and business continuity in the same decision cycle.

Observable evaluation cues

- Participants articulate a complete containment order rather than a single action.
- Participants understand the difference between password reset, MFA reset, token revocation, and session termination.
- Participants scope PAM and downstream systems before declaring containment complete.
- Participants keep business operations informed without allowing business pressure to defer security containment.

Inject 4 - Downstream Exposure and Business Impact Decisions

Simulated time	11:30
Incident stage	Scoping / crisis escalation / business impact
Primary decision	Whether to widen containment and activate crisis-management support.
Recommended time	18-20 minutes

Scenario narrative

The investigation shows the adversary used the privileged session to enumerate cloud groups, view privileged role memberships, and list several PAM vault folders. The session also accessed a SharePoint site containing privileged-access procedures and opened a dashboard listing critical business applications. A request to retrieve a payment-operations service credential appears to have failed due to PAM approval controls. Internal rumors begin circulating that a senior executive account was compromised through the help desk.

Technical artifacts available to participants

- PAM failed checkout record.
- Cloud group and role membership audit logs.
- SharePoint access logs for privileged procedure repository.
- ServiceNow search history and privileged reset ticket review.
- Internal rumor / communications prompt from business leadership.

Information provided to participants

- No confirmed external data exfiltration has been identified at this point.
- Sensitive internal procedures were accessed in SharePoint.
- The actor viewed names of privileged groups and several service account labels.
- A PAM password checkout request was initiated but not approved.
- Several urgent business approvals are delayed while alternate authorization is arranged.
- Legal and compliance ask whether the event is reportable and whether legal hold is needed.
- Communications asks whether employees should be warned about deepfake vishing attempts.

Discussion questions

- What are the most important scoping questions before declaring the incident contained?
- Which downstream systems must be reviewed first and why?
- Do you widen containment to related privileged accounts, service-desk admin accounts, or privileged reset approvers?
- What internal communications should be issued immediately?
- When does this move from a security incident to crisis-management activation?
- What legal, privacy, regulatory, fraud, or audit issues must be assessed now?
- What evidence would change the notification or escalation posture?

Expected participant actions

- Expand scope to systems reachable by the compromised identity and any roles or groups it viewed.
- Review PAM approval requests, failed password checkout attempts, role membership views, and session recordings.
- Search for access to repositories containing secrets, procedures, customer data, payment data, or privileged workflows.

- Review service-desk and IAM admin accounts for similar reset abuse or suspicious MFA changes.
- Prepare business workarounds for delayed approvals using documented alternate approvers or break-glass governance.
- Engage legal, compliance, privacy, fraud, and communications for notification analysis and stakeholder messaging.
- Preserve call recordings, ITSM tickets, IdP audit logs, PAM logs, cloud logs, and downstream application logs.
- Send targeted internal awareness to service desk and executive support teams without disclosing sensitive details.

Role ownership at this stage

Role / function	Expected ownership
Incident Commander / Crisis Lead	Determines whether crisis-management structure should be activated or kept on standby.
SOC / IR Lead	Leads technical scoping and identifies evidence that would indicate collection, exfiltration, or persistence.
IAM / PAM Leads	Widen containment and review privileged reset approvers, admin roles, break-glass paths, and vault access.
Legal / Compliance / Privacy	Assesses notification triggers, legal hold, records preservation, regulator expectations, and privacy impact.
Business Operations Lead	Coordinates alternate approvals and tracks operational delays.
Communications Lead	Prepares internal messaging, rumor control, and executive briefing materials.

Facilitator notes

This inject should test whether participants treat the help desk as a critical control plane. Good responses connect process failure, identity telemetry, PAM review, and business continuity rather than treating the event as a single-user account issue.

Observable evaluation cues

- Participants prioritize downstream systems based on privilege reach and sensitive data exposure.
- Participants separate confirmed facts from assumptions in leadership updates.
- Participants discuss reporting and notification as a decision process, not a reflex.
- Participants identify service-desk process containment as part of incident containment.

Inject 5 - Stabilization, Recovery, and Post-Incident Governance

Simulated time	15:00 and next business day
Incident stage	Recovery / lessons learned / control improvement
Primary decision	What must change before normal privileged reset operations resume.
Recommended time	15 minutes

Scenario narrative

Containment actions have terminated the attacker's sessions, removed the unauthorized MFA device, revoked tokens, and restored the real executive's access using a controlled in-person or trusted-channel process. No evidence of sustained persistence or confirmed external exfiltration has been found. However, the investigation confirms that the help-desk recovery workflow was defeated by deepfake-assisted impersonation, weak exception discipline, and insufficient technical guardrails around privileged recovery.

Technical artifacts available to participants

- Draft incident timeline and decision log.
- Account recovery checklist for legitimate user.
- Control gap list from service-desk workflow review.
- Executive readout template.
- Proposed detection logic for post-reset anomalies.

Information provided to participants

- The compromised access path has been disabled and sessions are revoked.
- The real executive confirms they did not make the call.
- The actor did not successfully check out the payment-operations credential.
- Sensitive procedure documents were viewed; no customer data export is confirmed.
- Privileged reset exceptions are temporarily suspended pending process review.
- Leadership asks for a post-incident readout and assurance that the same attack cannot succeed again.

Discussion questions

- What recovery steps are required before normal privileged access is restored?
- What compensating controls must be implemented within 24-72 hours?
- What long-term improvements are required across service desk, IAM, PAM, SOC, HR, and executive support?
- What should be included in the executive readout and post-incident report?
- What evidence must remain preserved and for how long?
- What regulatory, audit, customer-trust, or third-party considerations remain open?
- How will the organization validate that the revised process works?

Expected participant actions

- Complete account recovery for the legitimate user using a verified trusted channel.
- Maintain a temporary no-exception rule for privileged MFA resets until improved controls are implemented.
- Require dual approval and trusted callback for any privileged recovery request.
- Adopt phishing-resistant MFA for privileged users where feasible and harden temporary access method policy.

- Add high-fidelity alerts for MFA reset followed by new device enrollment, risky sign-in, PAM access, or admin console access.
- Update service-desk scripts, escalation decision trees, and analyst training for deepfake vishing.
- Produce a post-incident report with timeline, decisions, impacts, evidence, gaps, and remediation owners.
- Schedule a follow-up control validation or mini-tabletop after remediation.

Role ownership at this stage

Role / function	Expected ownership
Crisis Lead / Incident Commander	Owns final incident status, recovery exit criteria, and debrief process.
IAM Lead	Owns hardened recovery workflow, MFA policy, token controls, and monitoring improvements.
Service Desk Manager	Owns script updates, analyst training, exception-control design, and quality assurance.
SOC / IR Lead	Owns detection improvements, hunt queries, incident timeline, and evidence package.
Legal / Compliance / Privacy	Owns reporting decision memo, legal hold, retention, and regulatory engagement as applicable.
Business Operations Lead	Owns closure of delayed approvals and validation of business workaround effectiveness.

Facilitator notes

Do not let the group conclude that training alone solves the problem. The lesson should be layered control: process discipline, technical guardrails, phishing-resistant recovery, monitoring, governance, and executive awareness.

Observable evaluation cues

- Participants define recovery exit criteria before restoring normal operations.
- Participants produce measurable remediation actions with named owners and due dates.
- Participants identify both immediate compensating controls and longer-term strategic changes.
- Participants avoid unsupported claims such as 'no notification needed' without documenting the basis.

9. Cross-Functional Decision Points

Decision point	Question participants must answer
Privileged reset authorization	Who can approve, deny, or pause a privileged reset request when the user cannot complete standard verification?
Suspected compromise declaration	What evidence triggers account-compromise classification: failed callback, new MFA device, unusual sign-in, or PAM access?
Containment authority	Who can disable or restrict an executive-associated privileged account if business operations may be affected?
Token/session revocation	Who owns revocation across IdP, PAM, VPN / ZTNA, cloud admin portals, and critical applications?
Business workaround	Who approves alternate authorization paths while the privileged user is suspended?
Crisis activation	What triggers crisis-management activation versus standard security incident handling?
Notification analysis	Who decides whether regulator, customer, third-party, or law-enforcement notification is required?
Recovery exit criteria	Who signs off that normal privileged reset operations can resume after control changes?

10. Technical Evidence and Log Sources

Evidence source	Primary owner	Key questions
Call recording and metadata	Service Desk	Was the caller's number trusted? What pretext was used? What pressure tactics appeared? Was the call preserved?
ITSM ticket and approvals	Service Desk / IAM	Who approved the reset? Was privileged classification flagged? Were standard steps skipped?
IdP audit logs	IAM	Was a temporary access method issued? Was a new MFA device enrolled? Who performed each admin action?
Sign-in logs and conditional access	IAM / SOC	What IP, ASN, device, location, risk result, and policy decision appeared? Was access blocked, challenged, or allowed?
Session and token records	IAM / SOC	Which refresh tokens, SSO sessions, browser sessions, VPN sessions, and app sessions remained active?
PAM logs and session recordings	PAM Admin	Were vaults browsed, credentials checked out, secrets displayed, roles changed, or approvals requested?
Cloud / directory audit logs	IAM / SOC	Were accounts, groups, roles, apps, service principals, or conditional-access policies enumerated or changed?
Endpoint / device data	Endpoint Engineering	Was the enrolled device managed? Was there any sign of corporate endpoint use or remote access from unmanaged infrastructure?
Repository and collaboration logs	Application Owners	Were privileged procedures, sensitive repositories, customer data, or secrets accessed or downloaded?
DLP / CASB / network telemetry	SOC	Is there evidence of external sharing, unusual downloads, bulk export, or transfer to cloud storage?
Executive support records	HR / Executive Support	Was the real executive reachable? Did trusted contacts confirm or deny the request?
Incident timeline and decision log	Incident Commander	When were key facts known, who decided, and what was the rationale?

11. Expected Technical and Business Impacts

Technical impacts

- Unauthorized MFA factor enrollment or temporary access method use.

- Valid privileged account sessions across SSO, PAM, cloud admin consoles, and ITSM administration workflows.
- Exposure of privileged group names, service account labels, procedures, or vault metadata.
- Possible need to revoke tokens, terminate sessions, remove authentication methods, rotate secrets, and review privileged role assignments.
- Temporary loss of trust in the privileged recovery workflow and associated audit trail.
- Increased monitoring and hunt activity for similar reset abuse across other privileged accounts.

Business impacts

- Delayed executive or privileged business approvals while alternate authorization is established.
- Temporary suspension of high-risk reset exceptions and increased support friction.
- Potential operational impact if privileged accounts, PAM access, or workflows are restricted.
- Governance impact from unclear authority to disable business-sensitive privileged access.
- Reputational and trust impact if internal stakeholders believe executive impersonation succeeded.
- Potential regulatory, audit, or privacy review depending on data access, service disruption, or control weakness findings.

12. Communications and Regulatory Considerations

The exercise should not assume that notification is automatically required. Participants should determine whether notification thresholds are met based on confirmed facts, jurisdiction, customer impact, operational impact, data exposure, contractual obligations, and regulatory expectations.

Communication	Purpose	Owner
Internal service desk alert	Warn analysts that privileged voice reset exceptions are paused; reinforce trusted callback and escalation path.	Service Desk Manager / IAM
Executive briefing	Summarize facts, uncertainty, containment status, operational impact, and decisions needed from leadership.	Incident Commander / CISO Delegate
Business operations update	Explain approval delays, alternate authorization path, and expected operational workaround.	Business Operations Lead
Legal / compliance memo	Record facts relevant to notification, legal hold, evidence preservation, privacy exposure, and regulator engagement.	Legal / Compliance / Privacy
Employee awareness note	Reinforce deepfake vishing indicators and escalation route without disclosing sensitive details.	Communications / Security Awareness
External communication holding statement	Prepare but do not release unless approved; focus on confirmed operational impact and control actions.	Communications / Legal
Regulator or supervisory contact	Assess if timing, impact, and reporting criteria are met in relevant jurisdictions.	Compliance / Legal / Executive Sponsor

Regulatory and legal analysis prompts

- Was customer, employee, payment, trading, or confidential supervisory information accessed, viewed, exported, modified, or exposed?
- Did the incident materially disrupt a regulated business service or critical operation?
- Do contractual obligations require notification to customers, partners, vendors, insurers, or outsourcing stakeholders?
- Is legal hold required for call recordings, tickets, chat messages, identity logs, and PAM session recordings?
- Do employee-monitoring or privacy laws affect how call recordings and administrative logs are handled?
- Is law enforcement or fraud team engagement appropriate based on impersonation, attempted theft, or downstream financial risk?

- What facts are known, what remains uncertain, and who approves the notification decision memo?

13. Facilitator Prompts and Optional Branches

Prompts if discussion slows

- What exact evidence do you need before disabling the privileged account?
- What if the real executive is unreachable for two hours?
- Who can override business pressure when identity controls are not satisfied?
- Which session survives a password reset in your environment?
- Which downstream system would concern you most first: PAM, IdP, payment approvals, ITSM, or collaboration repositories?
- How would you know if the actor viewed but did not download sensitive information?
- What if a second similar reset request arrives while this incident is active?
- How do you distinguish authorized emergency handling from convenience-driven exception handling?

Optional branch injects for advanced audiences

Branch	New information	Training value
Branch A - Successful PAM checkout	A PAM approval misconfiguration allows the actor to check out a service account credential.	Tests secret rotation, service account dependencies, blast-radius analysis, and business continuity.
Branch B - Second targeted account	A second privileged reset request appears for an IAM administrator using similar pressure tactics.	Tests pattern recognition, service-desk process freeze, and broader hunt activity.
Branch C - Data access ambiguity	Logs show sensitive repository views but no download event due to logging limitations.	Tests privacy/legal analysis under uncertainty and executive communication discipline.
Branch D - Media rumor	An internal rumor leaks to a reporter asking whether an executive account was compromised.	Tests communications, legal coordination, and fact-based public posture.
Branch E - Conditional access gap	Conditional access allowed the sign-in because recovery sessions are exempted from risk-based policies.	Tests technical debt, compensating controls, and identity governance remediation.

14. Evaluation Criteria and Scorecard

Use a 1-5 scale for each criterion: 1 = not demonstrated, 2 = partially demonstrated, 3 = adequate, 4 = strong, 5 = exemplary. Capture evidence, not just opinions.

Criterion	Observable indicator
Social engineering recognition	Participants identify deepfake / vishing risk and do not rely on voice, caller ID, urgency, or internal knowledge as proof.
Privileged reset discipline	Participants apply no-exception privileged recovery steps and identify trusted callback / dual approval requirements.
Escalation clarity	Participants name who owns service-desk escalation, IAM decisioning, SOC incident classification, and crisis activation.
Technical containment	Participants execute or describe complete account restriction, token revocation, session termination, MFA cleanup, and secret rotation.
Evidence preservation	Participants preserve call recording, ticket trail, identity logs, PAM logs, admin audit logs, and decision rationale.
Downstream scoping	Participants identify reachable systems, privilege paths, data repositories, PAM vaults, service accounts, and related reset events.

Criterion	Observable indicator
Business continuity	Participants define alternate approval paths and manage operational disruption without weakening security decisions.
Communications	Participants provide fact-based internal, executive, and potential external messaging with uncertainty clearly marked.
Legal / regulatory analysis	Participants assess notification, legal hold, privacy, regulator, insurer, and contractual obligations based on facts.
Remediation quality	Participants define layered improvements with owners, due dates, validation methods, and measurable outcomes.

Suggested facilitator scoring notes

- Strong performance includes rapid denial of unsafe reset, early SOC/IAM escalation, and precise token/session containment.
- Adequate performance may identify the risk but lack a named decision owner or complete technical containment sequence.
- Weak performance includes accepting voice recognition, waiting for proof while active privileged sessions persist, or treating training as the only remediation.
- Record timing: when was the event classified, when was containment approved, when were sessions revoked, and when were stakeholders briefed?

15. Debrief and Lessons Learned

Debrief questions

- What decisions were made quickly and effectively?
- Where did uncertainty delay action or create disagreement?
- Which roles lacked clear authority, ownership, or escalation criteria?
- Which identity, PAM, ITSM, or log sources were hardest to access quickly?
- What business processes depended on the affected privileged identity?
- What evidence would have changed legal, regulatory, privacy, or communication decisions?
- What control changes would most reduce repeat risk within the next 30 days?
- How will remediation be validated, and who owns the validation?

Likely improvement themes

- No-exception privileged reset process with trusted out-of-band verification.
- Phishing-resistant MFA and hardened recovery methods for privileged identities.
- Tighter temporary access pass policy, short validity windows, and privileged-use restrictions.
- Detection correlation: privileged reset followed by new MFA enrollment, risky sign-in, PAM access, or admin-console discovery.
- Service-desk scripts that explicitly address executive pressure and deepfake vishing.
- Executive awareness that security controls cannot be waived verbally.
- Clear authority to restrict executive-associated privileged accounts during active compromise.
- Periodic control validation through follow-up tabletop, purple-team exercise, or audit test.

16. Recommended Follow-On Actions

Immediate: 24-72 hours

- Suspend informal privileged reset exceptions and require trusted callback for all high-risk recovery requests.
- Review recent privileged MFA resets for unusual new device enrollment, risky sign-ins, or downstream privileged access.
- Add a SOC watchlist for MFA reset followed by new device registration and privileged login within a short window.
- Validate the ability to revoke sessions and refresh tokens across IdP, PAM, VPN / ZTNA, cloud apps, and critical applications.
- Brief service desk, executive support, IAM, and SOC teams on the scenario and immediate decision tree.

Near term: 30 days

- Update privileged account recovery policy, scripts, approval workflow, and ITSM required fields.
- Create a RACI for privileged reset denial, approval, account disablement, and business workaround activation.
- Implement privileged recovery detection logic and alert routing to SOC / IAM with severity criteria.
- Harden temporary access methods: short validity, privileged restrictions, mandatory trusted callback, and automatic alerting.
- Run a sample audit of privileged reset tickets and compare actual evidence to policy requirements.
- Train analysts and supervisors on deepfake vishing, urgency pressure, and evidence preservation.

Strategic: 60-180 days

- Move privileged users to phishing-resistant MFA and reduce dependence on push-based or human-reset recovery paths.
- Implement just-in-time privileged access, stronger PAM approval controls, and session recording coverage.
- Integrate ITSM, IdP, PAM, HRIS, and executive-support data to automate high-risk reset checks.
- Define recovery guardrails for executive-associated privileged accounts and break-glass identities.
- Conduct recurring tabletop and technical validation exercises focused on identity recovery abuse.
- Measure remediation through control tests: blocked unsafe reset, alert generated, tokens revoked, and downstream scope completed.

17. MITRE ATT&CK Mapping

This mapping is limited to behavior represented in the scenario. Techniques are marked as Observed when directly represented, Conditional when dependent on optional branch evidence, and Excluded when deliberately not used because the scenario does not support them. The mapping avoids treating a help-desk MFA reset as generic account creation or unsupported malware activity.

Tactic	Technique	ID	Status	Scenario rationale
Reconnaissance	Gather Victim Identity Information: Employee Names	T1589.003	Observed / inferred	Actor uses internal names, executive details, and travel context to craft a credible pretext.
Initial Access	Social Engineering; Impersonation	T1684; T1684.001	Observed	Actor uses deepfake voice impersonation and urgency to influence help desk into unauthorized recovery action.
Initial Access / Defense Evasion	Valid Accounts; Cloud Accounts or Domain Accounts	T1078; T1078.004 / T1078.002	Observed	Actor authenticates using a legitimate privileged account after MFA recovery abuse. Use cloud or domain sub-technique based on actual identity platform.
Persistence / Privilege Escalation / Defense Evasion	Account Manipulation; Device Registration	T1098; T1098.005	Observed	Actor enrolls an attacker-controlled MFA device or recovery method to satisfy authentication and maintain access during the incident window.
Defense Evasion / Credential Access	Modify Authentication Process: Multi-Factor Authentication	T1556.006	Conditional	Use only if the actor or compromised admin changes MFA policy or authentication mechanisms. Do not use for a routine service-desk reset alone.
Discovery	Account Discovery: Cloud Account / Domain Account	T1087.004 / T1087.002	Observed	Actor views or enumerates accounts from cloud or domain directories after access.
Discovery	Permission Groups Discovery: Cloud Groups / Domain Groups	T1069.003 / T1069.002	Observed	Actor views group memberships, privileged roles, and authorization paths.
Discovery	Cloud Service Discovery	T1526	Observed	Actor enumerates cloud services and admin consoles reachable through SSO.
Discovery	Remote System Discovery	T1018	Conditional	Use if logs show enumeration of hosts, network resources, CMDB systems, or connected systems for lateral movement.
Collection	Data from Information Repositories; SharePoint / Messaging / Databases	T1213; T1213.002 / T1213.005 / T1213.006	Conditional	Use if the actor accesses or collects information from collaboration repositories, procedures, messages, or databases.

Techniques intentionally excluded unless new evidence appears

Technique	ID	Status	Reason
Compromise Accounts	T1586	Excluded	The scenario involves takeover or misuse of an existing account through recovery abuse, not creation or compromise of external accounts for infrastructure.
Brute Force / Password Guessing / Password Spraying	T1110 / sub-techniques	Excluded	No repetitive login guessing or password spraying is present. The actor already has credential material or uses temporary recovery access.
Command and Control	Multiple	Excluded	No malware or remote-control channel is introduced in the base scenario.
Exfiltration	Multiple	Excluded / optional branch	No confirmed export or transfer is present in the base scenario. Add only if branch evidence confirms external transfer.
Impact	Multiple	Excluded / optional branch	No destructive, disruptive, or encryption activity is represented in the base scenario.

Detection and response alignment by ATT&CK behavior

ATT&CK behavior	Detection cue	Response action
T1684 / T1684.001	Call contains urgency, authority pressure, caller-provided callback, and inability to pass MFA.	Service desk flags suspected social engineering, preserves call, performs trusted callback, escalates to IAM/SOC.
T1098.005	New MFA device enrolled shortly after help-desk recovery event, especially from unmanaged device or unusual location.	Remove factor, revoke tokens, review issuing admin, search for similar enrollments.
T1078	Privileged account login from unusual ASN, device, geography, impossible travel, or after reset.	Restrict account, terminate sessions, revoke refresh tokens, scope downstream activity.
T1087 / T1069 / T1526	Directory, group, role, or cloud service enumeration shortly after anomalous login.	Review admin audit logs, confirm whether changes occurred, widen scope to reachable assets.
T1213	Access to sensitive repositories, privileged procedures, customer data, messaging, or databases.	Determine data viewed/exported, apply legal hold, engage privacy/compliance, perform DLP/CASB review.

18. Appendix - Exercise Artifacts

Sample ITSM ticket fields to display during Inject 1

Caller name claimed	Senior technology executive / privileged account holder
Account requested	adm-j.smith or equivalent privileged administrative persona
Request type	MFA reset / temporary access method issuance
Business justification	Urgent approval required during travel
Verification result	Standard MFA failed; trusted callback not completed
Exception approver	Service desk supervisor via ticket comment
Risk flag	Privileged account / high-risk recovery
Evidence to preserve	Call recording, caller ID, callback number, analyst notes, approval comments

Sample IdP telemetry for Inject 2

Time	Event type	Description
09:18:42	Admin action	Temporary access method issued for privileged account by service desk admin.
09:21:07	MFA event	New authenticator app enrolled from unmanaged device fingerprint.
09:22:31	Sign-in	Successful SSO from commercial VPN / hosting ASN outside normal pattern.
09:23:05	Token event	Refresh token issued; session persists across multiple applications.
09:29:44	App access	PAM portal and cloud admin console accessed.

Glossary

Term	Meaning
ASN	Autonomous System Number; useful for identifying hosting providers, VPNs, and unusual network origins.
CASB	Cloud Access Security Broker; monitors cloud application use and data movement.
DLP	Data Loss Prevention; detects or controls sensitive data transfer.
EDR	Endpoint Detection and Response; monitors endpoints for suspicious activity.
HRIS	Human Resources Information System; trusted source for employee records and contact details.
IAM	Identity and Access Management; identity lifecycle, authentication, authorization, and access governance.
IdP	Identity Provider; platform that authenticates users and issues SSO sessions.
ITSM	IT Service Management; ticketing and workflow platform such as ServiceNow.
MFA	Multifactor Authentication; authentication using more than one factor.
PAM	Privileged Access Management; controls and monitors use of privileged accounts and secrets.
SIEM	Security Information and Event Management; central log collection and correlation.
SSO	Single Sign-On; authenticated access to multiple applications after one login.
TAP / temporary access method	Time-bound recovery mechanism used to bootstrap or restore access; should be tightly controlled for privileged identities.
UEBA	User and Entity Behavior Analytics; detects unusual patterns for users, devices, or service accounts.
ZTNA	Zero Trust Network Access; access model enforcing identity, device, and policy checks.

19. Appendix - Source Scenario Elements Interpreted

The source scenario described a financial-services organization facing a deepfake vishing attempt against a privileged-access workflow. The original elements included a threat actor using voice impersonation, a help-desk MFA reset attack pattern, an executive voice call pressuring a bypass of reset procedures, a privileged session anomaly after reset from an unusual location, and response measures focused on strict service-desk identity proofing and rapid privileged-account containment.

This enhanced version preserves that scenario intent while adding the technical architecture, telemetry, decision ownership, and ATT&CK precision needed for a higher-fidelity exercise.

20. Appendix - External Reference Notes

MITRE ATT&CK technique names and IDs in this document were checked against official MITRE ATT&CK Enterprise technique pages current at generation time. The exercise team should re-check ATT&CK references when maintaining the TTX in future versions.

ATT&CK ID	Reference topic
T1684 / T1684.001	Social Engineering / Impersonation
T1078 / T1078.004 / T1078.002	Valid Accounts / Cloud Accounts / Domain Accounts
T1098 / T1098.005	Account Manipulation / Device Registration
T1087	Account Discovery
T1069	Permission Groups Discovery
T1018	Remote System Discovery
T1526	Cloud Service Discovery
T1213	Data from Information Repositories